

Windows Privilege Escalation via Password Attacks

Password-based attacks are a key vector for privilege escalation on Windows systems. If attackers can obtain or bypass credentials for privileged accounts, they can elevate their privileges from a low-privileged user to an administrator or even SYSTEM. Below are common methods for exploiting password-based weaknesses, including techniques for enumerating credentials, bypassing User Account Control (UAC), and exploiting known vulnerabilities like PrintNightmare.

1. Password Enumeration - Saved Credentials and Password Hashes

One of the first steps in password-based attacks is enumerating saved credentials and password hashes. These credentials are often stored in files like Unattend.xml or in the system's credential manager. Additionally, tools like winPEAS can be used to enumerate saved credentials that could potentially be used to escalate privileges.

STEPS TO EXPLOIT:

Action	Command
Enumerate Windows credentials using winPEAS	<code>.\winPEASany.exe windowscreds</code>
Check for any saved credentials in Unattend.xml	<code>.\winPEASany.exe filesinfo</code>
If saved passwords are found, use them for login	<code>impacket-psexec admin:'password123'@10.10.227.97</code>
Result	SYSTEM shell via PsExec if you have admin credentials

Explanation: By using winPEAS and other enumeration tools, attackers can locate saved credentials in files like Unattend.xml. These credentials are often base64-encoded and may belong to highly privileged accounts like admin or SYSTEM. Once the credentials are extracted, tools like impacket-psexec can be used to gain access to the target system, potentially with SYSTEM-level privileges if the password allows it.

2. Saved Credentials - Using cmdkey and runas

Windows stores saved credentials in a local credential manager that can sometimes be leveraged for privilege escalation. This can include RDP credentials, network shares, and even administrative login credentials. Attackers can exploit saved credentials to run commands as a higher-privileged user.

STEPS TO EXPLOIT:

Action	Command
List saved credentials using cmdkey	cmdkey /list
Run a payload using saved credentials	runas /savecred /user:admin C:\Users\user\reverse.exe
Result	Elevated privileges as admin

Explanation: The cmdkey /list command allows attackers to see any saved credentials on the system, which might include credentials for administrators or network resources. Using runas with the /savecred option allows attackers to execute commands with elevated privileges, bypassing User Account Control (UAC) and running a reverse shell.

3. Additional Password Attacks and Considerations

Beyond the direct enumeration and exploitation of saved passwords and vulnerabilities, there are several other methods that can be used to escalate privileges or bypass authentication mechanisms:

LATERAL MOVEMENT AND REMOTE EXECUTION

Action	Command
Execute commands remotely using PsExec	<code>impacket-psexec -u admin -p password123 10.10.227.97</code>
Use RDP, SMB, or WinRM for lateral movement	<code>evil-winrm -i 10.10.227.97 -u admin -p password123</code>

Explanation: Once an attacker has obtained valid credentials (either through enumeration or brute-forcing), they can use tools like PsExec, evil-winrm, or SMB to perform lateral movement to other systems in the network or escalate privileges locally.

BRUTE FORCING AND PASSWORD CRACKING

If the attacker does not have access to valid credentials, they can attempt to brute force passwords using tools like hydra, medusa, or crackmapexec against RDP, SMB, or WinRM services.

Action	Command
Brute force RDP with hydra	<code>hydra -l admin -P /path/to/password_list.txt rdp://10.10.227.97</code>
Brute force SMB with crackmapexec	<code>crackmapexec smb 10.10.227.97 -u admin -p password123</code>

Explanation: In environments with weak or predictable passwords, brute-forcing is a viable option for attackers to gain access to privileged accounts. By using tools like hydra or crackmapexec, attackers can attempt thousands of password combinations quickly to break into services like RDP or SMB.

4. Defense Against Password-Based Privilege Escalation

To defend against password-based attacks, especially privilege escalation via password hashes or saved credentials, the following steps are recommended:

- Enforce Strong Password Policies:** Implement and enforce complex password policies to minimize the likelihood of weak or guessable passwords being used by privileged accounts.
- Regularly Rotate Passwords:** Ensure that passwords for highly privileged accounts (e.g., administrators, SYSTEM) are rotated regularly to limit the effectiveness of any password leaks or enumeration.
- Enable Multi-Factor Authentication (MFA):** Implement multi-factor authentication for administrative access, particularly for RDP and SMB, to prevent unauthorized access via password guessing or credential theft.
- Patch Vulnerabilities (e.g., PrintNightmare):** Ensure that all systems are up-to-date with the latest security patches, especially for critical vulnerabilities like PrintNightmare. Use Windows Update or patch management systems to apply patches promptly.
- Disable Unnecessary Services:** Disable or restrict services like the Print Spooler and remote desktop services when they are not necessary to reduce the attack surface.
- Monitor and Audit Access:** Regularly audit and monitor access to sensitive accounts and services, and implement logging for authentication attempts and successful logins to detect unauthorized access.

→**Restrict Saved Credentials:** Avoid storing sensitive credentials in plaintext or in places like the Unattend.xml file. Use a password manager to securely store and manage credentials.

Conclusion

Password attacks remain one of the most effective ways to escalate privileges in Windows environments. By enumerating saved credentials, exploiting known vulnerabilities, or bypassing authentication mechanisms, attackers can gain unauthorized access to systems with high-level privileges. It is crucial for organizations to implement strong password policies, apply security patches, and monitor user activity to defend against such attacks.